

MARIZFIRST

Technical Requirements Document (TRD)

Healthcare Appointment Discovery + Assisted Booking Platform

Item	Detail
Product	MarizFirst
Document type	Technical Requirements Document
Version	TRD v1.0
Source baseline	MarizFirst Product Requirements Document (PRD v1.0)
MVP model	Hybrid booking: patient selects a preferred slot, appointment remains Pending Confirmation until admin or partner approval
Core users	Patients, doctors, hospitals, clinics, MarizFirst admin team
Primary conversion	Appointment request followed by WhatsApp/admin/partner confirmation
Important positioning rule	Do not build or message the platform as a discount/coupon product. Build trust, verified profiles, clarity, and assisted appointment support.

Table of Contents

- 1. Technical Executive Summary
- 2. Product-to-Technology Translation
- 3. Architecture Principles and Non-Negotiables
- 4. Recommended Technology Stack
- 5. System Architecture Overview
- 6. Repository and Codebase Structure
- 7. Frontend Technical Requirements
- 8. Backend Technical Requirements
- 9. Database and Data Model Requirements
- 10. Appointment, Slot, and Lead Logic
- 11. API Requirements
- 12. Authentication, Authorization, and RBAC
- 13. Admin Panel Technical Requirements
- 14. Partner Dashboard Technical Requirements
- 15. Search, Filtering, and Discovery Requirements
- 16. Notifications and WhatsApp Integration
- 17. SEO Technical Architecture
- 18. Analytics and Event Tracking
- 19. Security, Privacy, and Compliance Requirements
- 20. Performance and Reliability Requirements
- 21. Accessibility Technical Requirements
- 22. CMS, Content, and Media Management
- 23. DevOps, Environments, and Deployment
- 24. Monitoring, Logging, and Incident Handling
- 25. Testing and QA Requirements
- 26. Data Seeding, Migration, and Operational Readiness
- 27. Implementation Milestones
- 28. Risks, Assumptions, Open Decisions
- 29. Engineering Definition of Done
- 30. PRD-to-TRD Traceability Matrix

1. Technical Executive Summary

This TRD converts the MarizFirst PRD into an engineering-ready technical specification. The platform must be built as a production healthcare appointment assistance system, not as a static listing website and not as a discount-led marketplace. The core technical responsibility is to reliably connect patient appointment requests with verified healthcare partners while preserving operational control, privacy, SEO scalability, and future extensibility.

Item	Technical Requirement
Core technical goal	Build a scalable web platform where patients can discover verified doctors, hospitals, and clinics, select a preferred slot, submit an appointment request, and receive clear confirmation updates.
Primary architecture pattern	Modular Next.js application with clean separation between public website, admin dashboard, partner dashboard, API/services, database repositories, and background notification workflows.
MVP booking rule	No public auto-confirmation. Appointment status starts as PENDING_CONFIRMATION and changes only after admin or partner action.
Data sensitivity rule	Patient phone, email, concern, appointment history, and notes must be treated as sensitive operational data.
SEO rule	Doctor, hospital, clinic, city, speciality, and blog pages must be server-rendered/indexable with dynamic metadata, schema, sitemap, canonical rules, and fast mobile performance.
Operational rule	Admin must be able to manage appointment status, partner response, reschedule/cancel flows, notifications, and audit history without developer dependency.

2. Product-to-Technology Translation

PRD Requirement	Technical Interpretation	Implementation Owner
Trusted healthcare discovery	Verified, status-controlled profiles with structured data, verification fields, SEO metadata, and admin approval workflow.	Backend + Admin + SEO
Hybrid booking	Transactional appointment creation with PENDING_CONFIRMATION status, slot capacity checks, notification triggers, and admin/partner action endpoints.	Backend
Short booking form	React Hook Form + Zod validation, accessible errors, consent capture, rate limiting, and source tracking.	Frontend + Backend
Admin operations	Secure RBAC admin panel for listings, appointments, leads, partners, content, SEO, notifications, audit logs, and metrics.	Backend + Frontend
Partner dashboard	Scoped partner access for own profile, slots, appointment requests, and reports. Ownership checks on every query and	Backend

	endpoint.	
WhatsApp updates	Official WhatsApp Business API integration with templates, retries, provider message IDs, status webhooks, and failure dashboard.	Backend + DevOps
Local SEO	Programmatic routes for city/specialty/profile pages, dynamic metadata, schema, internal linking, sitemap, and robots.	Frontend + SEO
Security and privacy	RBAC middleware, secure cookies, input validation, rate limits, CAPTCHA, audit logs, backups, export restrictions.	Security + Backend

3. Architecture Principles and Non-Negotiables

- Use a production MVP architecture, not throwaway static pages.
- Use server-rendered/indexable public pages for SEO-critical routes.
- Use hybrid appointment confirmation until partner slot discipline is proven.
- Keep domain logic inside service modules, not scattered directly inside UI components or route handlers.
- Enforce RBAC and ownership checks in backend logic, not only in UI.
- All critical state changes must produce audit logs.
- All appointment-related notifications must be stored and traceable.
- Soft delete sensitive business records; avoid destructive deletion except for controlled system maintenance.
- Design for city-wise and specialty-wise expansion from day one.
- Do not build EMR/EHR, teleconsultation, public reviews, AI diagnosis, or payments in Phase 1 unless later approved.

4. Recommended Technology Stack

Layer	Recommended Technology	Reason	MVP Priority
Frontend	Next.js App Router + TypeScript	SEO-friendly routing, server components, type safety, scalable app layout.	P0
Styling	Tailwind CSS + design tokens	Fast responsive UI, consistent spacing/color/type rules, maintainable design system.	P0
Forms	React Hook Form + Zod	Reliable validation, accessible errors, low rerender cost, shared schema logic.	P0
Database	PostgreSQL	Strong relational model for doctors, clinics, hospitals, slots, patients, leads, appointments, and audit logs.	P0
ORM	Prisma	Typed schema, migrations, relation mapping, safer query construction.	P0

Auth	NextAuth/Auth.js or custom credentials/OTP; Clerk only if speed is preferred over control	Role-based dashboards, secure session handling, optional OTP path.	P0
Admin/CMS	Custom RBAC admin or Payload CMS	Custom admin gives maximum workflow control; Payload speeds content/admin setup. Decision must be finalized before development.	P0
Notifications	Official WhatsApp Business API provider	Production-grade appointment communication with delivery statuses and templates.	P0
Media	Cloudinary or S3-compatible object storage with CDN	Optimized profile/gallery/media assets with transformations and CDN delivery.	P0
Analytics	GA4 + server-side event logging for key funnel events	Track acquisition, conversion, partner quality, and operational outcomes.	P0
Monitoring	Sentry + uptime monitor + structured logs	Production error tracking, failure visibility, incident debugging.	P0
Hosting	Vercel for Next.js + managed PostgreSQL	Fast MVP deployment, previews, CI integration, scalable public pages.	P0

4.1 Stack Decision Notes

- Custom admin is better if MarizFirst expects complex appointment operations, partner SLAs, and lead workflows.
- Payload CMS is faster if content and listing CRUD speed matters more than complex workflow customization in the first release.
- A separate NestJS backend is not required for MVP but the service/repository structure must keep migration possible.
- Avoid Firebase-only architecture for this product because relational appointment, partner, SEO, and audit needs are stronger than simple realtime needs.

5. System Architecture Overview

Subsystem	Responsibilities	Key Technical Notes
Public website	Home, listings, search, doctor/hospital/clinic profiles, city/specialty pages, blogs, legal pages.	Mostly server-rendered with selective client components for filters, slot picker, forms, and drawers.
Patient booking service	Validate form, check slot, create patient, appointment, lead, notifications, audit log.	Must be transactional. Must prevent overbooking and duplicate spam submissions.
Admin dashboard	Appointments, listings, leads, partners, content, SEO, notifications, audit logs, metrics.	Protected routes with admin RBAC and audit logging.
Partner dashboard	Scoped profile, slots, appointment	Ownership checks at query/service/API

	actions, basic reports.	level.
Notification service	WhatsApp templates, queue, send, retry, status webhook, logs.	Do not block appointment creation on external provider failure; log and retry.
SEO service	Metadata generation, schema JSON-LD, sitemap, robots, redirects, canonical logic.	Must consume published content/profile data only.
Analytics service	Client and server event capture for funnel and operational metrics.	Avoid sending sensitive health concern data to GA4.
Audit service	Record sensitive actions and state changes.	Append-only logs. No partner/content editor delete access.

6. Repository and Codebase Structure

Recommended Next.js monorepo folder structure:

```
src/
  app/
    (public)/
      page.tsx
      doctors/page.tsx
      doctors/[city]/page.tsx
      doctors/[speciality]/[city]/page.tsx
      doctor/[slug]/page.tsx
      hospitals/page.tsx
      hospital/[slug]/page.tsx
      clinics/page.tsx
      clinic/[slug]/page.tsx
      specialities/[slug]/page.tsx
      cities/[slug]/page.tsx
      blog/page.tsx
      blog/[slug]/page.tsx
      contact/page.tsx
      partner-with-us/page.tsx
      privacy-policy/page.tsx
      terms/page.tsx
      medical-disclaimer/page.tsx
      partner-terms/page.tsx
      data-deletion/page.tsx
    (dashboard)/
      admin/page.tsx
      admin/appointments/page.tsx
      admin/doctors/page.tsx
      admin/hospitals/page.tsx
      admin/clinics/page.tsx
      admin/partners/page.tsx
      admin/content/page.tsx
      admin/seo/page.tsx
      admin/audit-logs/page.tsx
      partner/page.tsx
      partner/profile/page.tsx
      partner/slots/page.tsx
      partner/appointments/page.tsx
    api/
      search/route.ts
      appointments/route.ts
      webhooks/whatsapp/route.ts
      admin/**/route.ts
      partner/**/route.ts
    sitemap.ts
    robots.ts
  components/
    ui/
    layout/
    public/
    booking/
    dashboard/
    forms/
  server/
    services/
```

```

appointment.service.ts
slot.service.ts
notification.service.ts
search.service.ts
seo.service.ts
audit-log.service.ts
partner.service.ts
repositories/
  appointment.repository.ts
  doctor.repository.ts
  hospital.repository.ts
  clinic.repository.ts
  slot.repository.ts
  patient.repository.ts
lib/
  auth.ts
  db.ts
  permissions.ts
  validators.ts
  seo.ts
  analytics.ts
  rate-limit.ts
  env.ts
styles/
types/
prisma/
  schema.prisma
  migrations/
  seed.ts
  seed-data/
tests/
  unit/
  integration/
  e2e/

```

7. Frontend Technical Requirements

Area	Requirement	Acceptance Criteria
Rendering	SEO pages should use server components/static or dynamic SSR where appropriate.	Doctor, hospital, clinic, city, speciality, and blog pages render metadata and content server-side.
Client components	Use client components only for interactive pieces: search autocomplete, filter drawer, slot picker, booking form, dashboard actions.	No unnecessary large client bundle for static content.
Responsive UI	Support 360, 390, 430, tablet, 1366, 1440, and 1920 widths.	No horizontal scroll, clipped cards, unusable filters, or hidden CTAs.
Design tokens	Centralize colors, spacing, typography, shadows, radii, and semantic status tokens.	UI is consistent across public, admin, and partner screens.
Forms	Use React Hook Form + Zod with visible labels, accessible errors, and consent checkbox.	Invalid forms do not submit and errors are read by assistive tech.
Loading states	Use skeletons for listings/profiles and dashboard tables.	Users are never left with blank states during data fetch.
Empty states	Helpful no-result and no-data states with next action.	Search no-results suggests nearby city/speciality or WhatsApp support.
Error states	Show user-safe errors and log technical details server-side.	No stack traces exposed to users.

Mobile CTA	Profile pages must have sticky Book Appointment and WhatsApp Support CTAs on mobile.	CTA remains reachable without covering form fields.
Accessibility	Keyboard, focus, labels, color contrast, modal/drawer focus return.	WCAG AA target for patient-facing UI.

8. Backend Technical Requirements

Area	Requirement	Notes
Service layer	Business logic must live in services, not directly inside route handlers.	Improves testing, maintainability, and future backend migration.
Repository layer	Database access should be isolated through repositories or dedicated query functions.	Avoid scattered Prisma calls across UI and API.
Transactions	Appointment creation, slot capacity update, lead creation, notification queue creation, and audit log should be transactional where needed.	Prevents inconsistent appointment state.
Validation	All public/admin/partner inputs validated with Zod or equivalent server-side validation.	Client validation is not enough.
Rate limiting	Apply rate limits to booking form, search abuse, auth endpoints, and WhatsApp support actions.	Protects operations from spam.
Audit logging	Sensitive operations must write audit logs.	Status changes, exports, login failures, profile verification changes, permission changes.
Soft delete	Use status/deletedAt fields for business records.	Preserves history and avoids accidental data loss.
Idempotency	Appointment submission and webhook processing should avoid duplicate processing.	Use idempotency keys or provider message IDs where applicable.
Background jobs	Notification retries and reminders should run through queue/cron process.	Do not rely only on request lifecycle for delayed work.

9. Database and Data Model Requirements

Entity	Required Fields / Relationships	Technical Rules
User	id, name, email, phone, passwordHash/providerId, role, status, lastLoginAt, createdAt, updatedAt	Unique email/phone where applicable; role enum; soft-disable instead of deletion.
Doctor	id, userId, name, slug, specialityId, cityId, qualification, experienceYears,	Slug unique; linked to user optionally; status controls public visibility.

	registrationNo, fee, bio, languages, gender, status, seoTitle, seoDescription	
Hospital	id, partnerUserId, name, slug, cityId, address, facilities, description, gallery, status, seo fields	Can have linked doctors; public only when active/published.
Clinic	id, partnerUserId, name, slug, cityId, address, feeRange, facilities, gallery, status, seo fields	Can have linked doctors/team and slots.
Speciality	id, name, slug, description, icon, seoTitle, seoDescription, content sections	Used for filters, profiles, city-speciality pages.
City	id, name, slug, state, seoTitle, seoDescription, content sections	Used for local SEO and filtering.
Location	id, cityId, area, address, latitude, longitude, mapUrl	Normalize areas for city pages and maps.
AppointmentSlot	id, ownerType, ownerId, startAt, endAt, capacity, bookedCount, status	Indexed by owner, date, status; capacity checks required.
Appointment	id, patientId, doctorId/hospitalId/clinicId, slotId, status, source, concern, adminNotes, partnerNotes, timestamps	Status state machine enforced in service layer.
Patient	id, name, phone, email, cityId, consentAt, createdAt, updatedAt	Phone indexed; sensitive data access restricted.
Lead	id, patientId, appointmentId, sourcePage, UTM fields, status	Links acquisition source to appointment outcome.
Notification	id, recipientType, recipientId, channel, template, status, sentAt, errorMessage, providerMessageId, retryCount	Required for notification observability and retries.
AuditLog	id, actorId, action, entityType, entityId, beforeJson, afterJson, ipAddress, userAgent, createdAt	Append-only. No normal user delete permission.
BlogPost	id, title, slug, excerpt, content, category, status, publishedAt, seoTitle, seoDescription	Published posts appear in sitemap.
FAQ	id, ownerType, ownerId, question, answer, sortOrder, isPublished	Can attach to doctor/hospital/clinic/city/speciality pages.
Redirect	id, sourcePath, destinationPath, statusCode, active	For SEO-safe slug changes and migrated pages.
Commission/ListPlan	appointmentId/partnerId fields, planType/monthlyFee/status, dueDate/paidAt	Can be data-only in Phase 1 without payment gateway.

9.1 Required Indexes

- Doctor: slug unique, cityId, specialityId, status, name search index.

- Hospital/Clinic: slug unique, cityId, status, name search index.
- AppointmentSlot: ownerType + ownerId + startAt, status, startAt.
- Appointment: status, createdAt, partner/profile ids, patientId, source.
- Patient: phone, email where available.
- Lead: sourcePage, UTM fields, status, createdAt.
- Notification: status, providerMessageId, createdAt, retryCount.
- AuditLog: actorId, entityType + entityId, createdAt.
- BlogPost/City/Speciality: slug unique, status/publishedAt.

10. Appointment, Slot, and Lead Logic

Workflow Step	Technical Requirement
Slot selection	Only AVAILABLE slots with remaining capacity are selectable. Past slots are EXPIRED and unavailable.
Form submission	Validate name, phone, city, preferred slot, consent, optional concern/email. Reject invalid or rate-limited requests.
Patient upsert	Create or update patient by phone/email while preserving consent timestamp and avoiding duplicate patient records.
Appointment create	Create appointment with PENDING_CONFIRMATION status. Do not show confirmed state to patient.
Capacity handling	Either increment bookedCount during pending state or place slot on HOLD based on final strategy. In both cases, prevent overcapacity.
Lead create	Create Lead with sourcePage, UTM parameters, profile type, and acquisition source.
Notifications	Queue patient acknowledgement, admin alert, and partner alert. External provider failure must not roll back appointment unless system policy requires it.
Audit log	Record appointment creation, source, actor system/public, and status.
Admin/partner action	Confirm, reschedule, cancel, complete, no-show, or lost actions must validate allowed transitions.
SLA tracking	Pending appointments approaching 15-30 minute SLA breach should be highlighted in admin dashboard.

Appointment Status	Meaning	Allowed Next Statuses	Rules
PENDING_CONFIRMATION	Patient submitted request; not final.	CONFIRMED, RESCHEDULED, CANCELLED, LOST	Default initial state.
CONFIRMED	Admin/partner approved final appointment.	COMPLETED, CANCELLED, RESCHEDULED, NO_SHOW	Patient notification required.
RESCHEDULED	Original slot changed.	CONFIRMED, CANCELLED, LOST	New slot and reason should be stored.
CANCELLED	Appointment cancelled.	Closed; new appointment	Reason recommended.

		required if needed.	
COMPLETED	Patient visit completed.	Closed	Used for partner quality and commission.
NO_SHOW	Patient did not attend.	Closed unless admin reopens manually.	Reason/notes recommended.
LOST	Lead could not convert or confirm.	Closed	Reason required.

11. API Requirements

Endpoint	Method	Purpose	Access	Critical Rules
/api/search	GET	Search doctors, hospitals, clinics, specialties, cities.	Public	Sanitize query; return type labels; cache safe responses if possible.
/api/appointments	POST	Create appointment request.	Public	Rate limit; validate; transaction; PENDING_CONFIRMATION only.
/api/appointments/[id]	GET	Read appointment details.	Admin/Partner scoped	Never expose unrelated appointment data.
/api/admin/appointments/[id]/confirm	POST	Confirm appointment.	Admin	Validate transition; notify patient; audit log.
/api/admin/appointments/[id]/reschedule	POST	Reschedule appointment.	Admin	Validate new slot; notify patient and partner; audit log.
/api/admin/appointments/[id]/cancel	POST	Cancel appointment.	Admin	Reason recommended; notify; audit log.
/api/admin/doctors	POST/PATCH	Manage doctor profiles.	Admin	Validate slug uniqueness, SEO fields, verification fields.
/api/admin/hospitals	POST/PATCH	Manage hospital profiles.	Admin	Validate linked doctors and media.
/api/admin/clinics	POST/PATCH	Manage clinic profiles.	Admin	Validate linked team, location, status.
/api/admin/blogs	POST/PATCH	Manage blog posts.	Content/Admin	No medical guarantees; metadata required before publish.
/api/partner/slots	POST	Create/edit available slots.	Partner	Owner-scoped; conflict/capacity validation.
/api/partner/	POST	Partner accepts	Partner scoped	Ownership check;

appointments/[id]/accept		request.		transition to CONFIRMED or partner accepted state.
/api/partner/appointments/[id]/reject	POST	Partner rejects request.	Partner scoped	Ownership check; reason; admin/patient notification path.
/api/webhooks/whatsapp	POST	Receive WhatsApp delivery/status webhook.	System	Verify signature/provider secret; idempotent processing.

12. Authentication, Authorization, and RBAC

Role	Technical Access	Restrictions
Super Admin	Full system, users, settings, finance, audit logs.	Dangerous actions require confirmation; no normal deletion of audit logs.
Admin	Listings, appointments, leads, slots, partners, blogs, SEO.	Cannot change super admin ownership or delete audit logs.
Content Editor	Blogs, SEO content, FAQs, static pages, images.	No patient data, no financial data, no appointment notes.
Doctor Partner	Own profile, slots, appointment requests.	No unrelated partner data; no permanent deletion of patient records.
Hospital Partner	Own hospital profile, linked doctors, scoped appointments/reports.	No unrelated hospital/clinic/doctor leads.
Clinic Partner	Own clinic profile, slots, appointments.	Export and bulk data restricted.
Public/Patient	Browse pages and submit appointment request.	No patient dashboard in Phase 1 unless later approved.

12.1 RBAC Implementation Rules

- Every dashboard route must require authenticated session.
- Every admin/partner API endpoint must call a permission guard before data access.
- Ownership checks must be enforced in database query constraints, not only after fetching records.
- Partner-scoped queries must include partnerUserId/organization ownership filters.
- Sensitive exports must require explicit permission and create audit logs.
- Session cookies must be secure, HTTP-only, SameSite, and production-only secure flag enabled.
- MFA should be considered for super admin/admin accounts if available in the selected auth solution.

13. Admin Panel Technical Requirements

Admin Module	Technical Requirements	Priority
Dashboard	Aggregate appointment counts, pending SLA warnings, lead source performance, top partners, notification failures.	P0

Appointments	Filter by status/date/doctor/hospital/clinic/city/source; status actions; notes; notification status; audit timeline.	P0
Doctors	CRUD, verification, fees, qualifications, media, SEO fields, FAQs, active/inactive status.	P0
Hospitals/Clinics	CRUD, facilities, gallery, city/location, linked doctors/team, CTA behavior, status.	P0
Slots	View partner slots, block slots, bulk creation, conflict resolution, capacity rules.	P0
Partners	Create accounts, assign role, manage status, plans, permissions, commission fields.	P0
Leads	Lead status, source tracking, contact notes, export with permission checks.	P0
Content	Blogs, categories, FAQs, homepage sections, legal/static pages.	P0
SEO	Meta fields, slugs, schema settings, redirects, sitemap inclusion, canonical settings.	P0
Finance	Commission fields, listing plans, partner dues, payment status data only; no gateway in Phase 1.	P1
Audit Logs	Search/filter sensitive actions, exports, login failures, profile changes, appointment state changes.	P0

14. Partner Dashboard Technical Requirements

Partner Module	Technical Requirements	Priority
Login	Secure authentication and role-scoped redirect.	P0
Profile Management	Partner can update own profile fields; sensitive fields may require admin review.	P0
Slot Management	Create, edit, block, bulk create slots; prevent conflicts and past slots.	P0
Appointment Requests	Accept, reject, request reschedule, mark completed/no-show; notes.	P0
Patient Details	Show only appointment-specific data after request. Mask or restrict where	P0

	appropriate.	
Reports	Appointments by period, pending, confirmed, completed, no-show, source summary.	P1
Support Requests	Partner can request profile/content/operational support from admin.	P1

15. Search, Filtering, and Discovery Requirements

Requirement	Technical Detail	Acceptance Criteria
Global search	Support doctor, hospital, clinic, speciality, city, and area terms.	Relevant results with type labels and fallback suggestions.
Listing filters	City, speciality, gender, fee range, availability, experience, profile type where data exists.	Filters update results and preserve SEO-safe canonical behavior.
Mobile filters	Drawer with Apply, Reset, and close behavior.	No permanent screen blockage; focus managed.
No results	Show useful alternatives and WhatsApp/support action.	No dead-end search pages.
Pagination	Use pagination or cursor loading for large lists.	No heavy payload that hurts Core Web Vitals.
Search indexes	DB indexes on slug, city, speciality, status, name; optional full-text search later.	Search performance remains practical at launch data scale.

16. Notifications and WhatsApp Integration

Notification	Recipient	Trigger	Data Required
Acknowledgement	Patient	Appointment submitted.	Patient name, provider/profile name, requested date/time, Pending Confirmation status, support contact.
New request alert	Admin	Appointment submitted.	Patient details, profile, selected slot, source page, UTM, CTA to admin appointment.
Partner request alert	Doctor/hospital/clinic	Appointment submitted for their profile.	Scoped patient details, requested slot, accept/reject/reschedule action.
Confirmation	Patient	Admin/partner confirms.	Confirmed date/time, address, provider, instructions, support

			contact.
Reschedule update	Patient + partner	Slot changed.	Old slot, new slot, reason if available.
Cancellation	Patient + partner	Appointment cancelled.	Cancelled appointment details and support option.
Reminder	Patient	12-24 hours before confirmed appointment.	Confirmed time, address, arrival note, support contact.

16.1 Notification Engine Rules

- Use official WhatsApp Business API. Do not depend on unofficial WhatsApp Web automation.
- Store providerMessageId, sentAt, status, failure reason, retry count, and raw webhook payload where useful.
- Webhook processing must verify provider signature/secret and be idempotent.
- Failed notifications must surface in admin dashboard with retry action.
- Templates must avoid medical advice, treatment guarantees, emergency-care claims, or discount-led positioning.
- Delayed reminders should use cron/queue and must not rely on a user opening the website.

17. SEO Technical Architecture

SEO Asset	Technical Requirement	Priority
Dynamic metadata	Use generateMetadata for doctor, hospital, clinic, city, speciality, and blog pages.	P0
Sitemap	Generate dynamic sitemap from published public profiles, city pages, speciality pages, and blog posts.	P0
Robots	Allow public pages; block dashboards, admin, partner, private APIs, staging.	P0
Schema	Implement Physician, MedicalOrganization, LocalBusiness, BreadcrumbList, FAQPage where appropriate.	P0
Canonical	Canonical URLs for city/speciality variations and filtered pages.	P0
Internal linking	Doctor profile links to speciality/city/hospital/clinic pages; city pages link to relevant specialities and profiles.	P0
Image SEO	Descriptive filenames, alt text, optimized sizes, lazy loading below fold.	P0
Redirects	Redirect table for slug changes and legacy URLs.	P1

18. Analytics and Event Tracking

Event	Trigger	Required Properties	Privacy Rule
search_performed	User submits search.	query, city, speciality, result_count, page_location	Do not include medical concern text.
listing_filter_applied	User applies filters.	filter_type, filter_value, page_type	No patient identifiers.
profile_viewed	Profile viewed.	profile_id, profile_type, city, speciality, source_page	No patient identifiers.
slot_selected	User selects slot.	slot_id, profile_id, profile_type, date, time	No patient identifiers.
appointment_form_started	User starts form.	profile_id, source_page	No typed form values.
appointment_submitted	Appointment request created.	appointment_id, profile_id, source_page, status	Avoid sending phone/email to GA4.
whatsapp_cta_clicked	WhatsApp CTA clicked.	page_type, profile_id, location	No phone in event payload.
appointment_confirmed	Admin/partner confirms.	appointment_id, partner_id, time_to_confirm	Internal analytics only where needed.
appointment_rescheduled	Appointment rescheduled.	reason category, appointment_id, actor_role	Avoid sensitive notes.
appointment_cancelled	Appointment cancelled.	reason category, appointment_id, actor_role	Avoid sensitive notes.

19. Security, Privacy, and Compliance Requirements

Risk	Technical Control	Acceptance Criteria
Broken access control	RBAC middleware, ownership-scoped queries, permission tests.	Partner cannot access another partner appointment via URL/API manipulation.
Injection	Prisma parameterized queries, Zod validation, reviewed raw SQL only.	Malicious inputs do not change query behavior.
Sensitive data exposure	HTTPS, secure cookies, restricted exports, backups, masked UI where appropriate.	Patient phone/concern not public or visible to unrelated roles.
Spam/fake leads	Rate limiting, CAPTCHA/Turnstile, optional phone OTP if spam increases.	Repeated submissions are throttled/challenged.
Admin misuse	Audit logs, least privilege, export restrictions, review process.	Sensitive actions are traceable.
Partner data leakage	Partner-scoped APIs only.	Partner sees only own assigned records.
Secrets leakage	Environment variables, no keys in repo, secret scanning.	No API keys committed.

Backup failure	Automated daily DB backups and restore testing.	Restore process documented and tested periodically.
----------------	---	---

- Mandatory legal pages: Privacy Policy, Terms and Conditions, Medical Disclaimer, Partner Terms, Data Deletion Request.
- Medical disclaimer must state that MarizFirst is appointment assistance and healthcare discovery, not emergency care, diagnosis, treatment guarantee, or replacement for qualified medical advice.
- Do not send patient concern text to public analytics tools.
- Apply minimum necessary data access for all roles.

20. Performance and Reliability Requirements

Area	Requirement	Target / Acceptance
Core Web Vitals	Optimize LCP, CLS, INP for public pages, especially mobile.	No oversized hero/profile images; stable layout; minimal client JS.
Images	Resize, compress, CDN, lazy-load below-fold gallery images.	Profile/listing pages load fast on mobile networks.
Search	Indexed database queries; pagination/cursor loading.	Search remains responsive at launch data scale.
Appointments	Transactional creation and status updates.	No duplicate/inconsistent appointment state under normal concurrency.
Notifications	Queue/retry, failure logs, webhook statuses.	External provider failure is visible and recoverable.
Dashboards	Loading, empty, failed states.	Admin can recover from API failure/retry.
Caching	Cache public stable data where safe; avoid caching private dashboards.	Freshness and privacy preserved.
Availability	Use uptime monitoring and error alerts.	Incidents noticed before user complaints where possible.

21. Accessibility Technical Requirements

- All inputs must use visible labels; placeholders cannot be the only label.
- Keyboard navigation must work for search, filters, forms, modals, drawers, and dashboard actions.
- Focus states must be visible and high contrast.
- Text and controls should meet WCAG AA contrast targets.
- Images need meaningful alt text when informative; decorative images should be hidden from assistive tech.
- Error messages must be connected to fields using aria-describedby or equivalent.
- Drawers/modals must not trap focus permanently; focus returns to trigger after close.
- Tap targets should be at least 44px high for key mobile actions.
- Appointment status should not rely on color alone; use text labels/icons.

22. CMS, Content, and Media Management

Content Type	Required Capabilities	Rules
Doctor profiles	CRUD, status, verification, media, SEO, FAQs, slots relationship.	Cannot publish incomplete critical profile fields.

Hospital/Clinic profiles	CRUD, gallery, facilities, linked doctors/team, SEO, status.	Public visibility controlled by status.
City/Speciality pages	Editable intro/content/FAQs, metadata, internal links.	Avoid medical claims and duplicate thin pages.
Blog posts	Draft, review, publish, category, author, metadata.	Medical disclaimer sensitivity review required.
Legal pages	Editable but protected from low-privilege roles.	Must remain indexable unless policy requires noindex.
Media	Upload, alt text, filename, transformation, deletion control.	Optimize before delivery; avoid huge uncompressed images.
Redirects	Manage source/destination/status.	Use for slug changes and removed pages.

23. DevOps, Environments, and Deployment

Environment	Purpose	Requirements
Local	Developer work.	Local env file, seed data, local or shared dev DB, clear README setup.
Staging	QA/UAT before production.	Production-like env vars, test WhatsApp templates/provider sandbox where possible, protected access.
Production	Live MarizFirst MVP.	Domain, SSL, analytics, Search Console, backups, monitoring, secure secrets.

DevOps Area	Requirement
Repository	Private GitHub repo, protected main branch, pull request reviews if team size allows.
CI	Run lint, typecheck, unit tests, build check, Prisma migration check.
CD	Preview deployments for PRs; staging deployment before production.
Secrets	Use platform secret manager. Never commit .env files.
Database	Managed PostgreSQL with backups and migration process.
Backups	Daily automated backup and periodic restore test.
Rollback	Document rollback for frontend deployment and database migrations.
Observability	Sentry, uptime monitor, structured logs, notification failure dashboard.

24. Monitoring, Logging, and Incident Handling

- Log errors with request ID, user role, endpoint, and safe contextual data.
- Do not log patient concern text or sensitive personal data unless strictly necessary and access-controlled.
- Track appointment creation failures, notification failures, webhook failures, and partner action errors.
- Admin dashboard should surface failed notifications and pending SLA breaches.
- Use Sentry for frontend/backend exceptions and performance traces where useful.
- Use uptime monitoring for public website and critical API health.
- Create a basic incident playbook: detect, classify, fix/rollback, communicate, post-incident review.

25. Testing and QA Requirements

Testing Type	Scope	Critical Scenarios
Unit tests	Validators, role checks, slot logic, status transitions, SEO helpers.	Invalid phone/consent; invalid status transition; expired slot.
Integration tests	Appointment create-confirm-cancel, partner accept/reject, notification queue.	Search -> profile -> booking -> admin confirm.
E2E tests	Patient and dashboard workflows in browser.	Patient submits request; admin confirms; partner cannot access other data.
Responsive QA	360/390/430, tablet, 1366/1440/1920.	No broken listing cards, filter drawer, sticky CTA, dashboard tables.
SEO QA	Metadata, schema, sitemap, robots, canonical, redirects.	Published profile appears in sitemap with correct metadata/schema.
Security QA	RBAC bypass, rate limits, input validation, protected routes.	URL manipulation cannot reveal another partner appointment.
Performance QA	Core Web Vitals, image sizes, pagination, caching.	Mobile pages stay fast with real content.
Accessibility QA	Keyboard, focus, labels, color contrast, errors, drawers.	Booking flow usable without mouse.
Operational QA	Failed partner response, reschedule, retry notifications.	Admin can manually recover workflow.

26. Data Seeding, Migration, and Operational Readiness

- Seed launch cities, specialties, sample doctors, hospitals, clinics, FAQs, and legal pages for staging.
- Production import must use verified real partner data, not placeholder fake profiles.
- Use Prisma migrations for schema changes; do not manually change production schema without migration history.
- Slug generation must avoid duplicates and support redirects after changes.
- Before launch, create admin SOP for pending appointment handling, partner follow-up, reschedule/cancel, and notification retry.
- Prepare partner onboarding checklist: profile data, verification data, location, services, fees, slot rules, contact person, WhatsApp consent/template needs.

27. Implementation Milestones

Milestone	Engineering Output	Exit Criteria
-----------	--------------------	---------------

M1 Foundation	Repo, Next.js, TypeScript, Tailwind, Prisma, DB, auth base, env validation.	App runs locally/staging; lint/typecheck/build pass.
M2 Data Model	Core Prisma models, migrations, seed data, repositories.	Data can be created/read safely with tests.
M3 Public Website	Home, listings, profile pages, SEO metadata, responsive layout.	Users can discover profiles and navigate core pages.
M4 Booking Engine	Slot picker, booking form, appointment/lead creation, Pending Confirmation.	Patient can submit appointment request end-to-end.
M5 Admin Operations	Admin dashboard, appointments inbox, listings CRUD, status actions, audit logs.	Admin can operate the booking workflow without developer help.
M6 Partner Dashboard	Partner login, profile, slots, appointment actions.	Partner can manage own workflow only.
M7 Notifications	WhatsApp templates, queue, webhook, retries, failure UI.	Patient/admin/partner messages work and failures are visible.
M8 SEO + Analytics	Sitemap, robots, schema, events, Search Console/GA4 config.	SEO and funnel tracking ready.
M9 QA + Security	E2E, responsive, accessibility, RBAC, performance, launch checklist.	All P0 acceptance scenarios pass.
M10 Production Launch	Domain, SSL, backups, monitoring, final seed data, SOP.	Live MVP with first-week monitoring plan.

28. Risks, Assumptions, and Open Decisions

Risk	Impact	Technical Mitigation
Fake availability	Patient trust breaks.	Use Pending Confirmation, SLA dashboard, partner escalation.
Slow partner response	Conversion loss.	Admin manual override, SLA alerts, WhatsApp support path.
Low-quality profile data	Poor SEO/conversion.	Admin verification checklist and publish requirements.
Spam appointments	Operational waste.	Rate limits, CAPTCHA, optional phone OTP.
Partner data leakage	Privacy/legal risk.	Strict RBAC, ownership checks, audit tests.
Overbuilding early	Delayed launch.	Do not build app, EMR, teleconsultation, payments, AI diagnosis in Phase 1.
WhatsApp approval delay	Notification launch risk.	Build manual fallback/admin copy actions; start template approval early.

- Open decision: final launch city and first specialties.

- Open decision: Payload CMS vs custom admin.
- Open decision: phone OTP at launch or only after spam appears.
- Open decision: WhatsApp provider and template approval timeline.
- Open decision: partner profile edit approval rules.
- Open decision: commission/listing plan fields and partner agreement rules.

29. Engineering Definition of Done

- All P0 public, admin, partner, booking, notification, SEO, security, and analytics requirements are implemented.
- Search -> profile -> slot -> booking -> admin/partner confirmation -> patient notification works end-to-end.
- No patient data is visible publicly or across unrelated partner accounts.
- All public pages are responsive, accessible, SEO-ready, and performant on mobile.
- Admin can manage profiles, appointments, partners, leads, content, SEO, and statuses without developer help.
- Partner can manage only their own profile, slots, and appointment requests.
- Audit logs exist for sensitive operations and status changes.
- WhatsApp failures are logged and retryable.
- Legal pages and medical disclaimer are live.
- GA4/Search Console/conversion events are configured without leaking sensitive data.
- Backups, monitoring, production environment variables, and rollback process are configured.
- Critical E2E, RBAC, responsive, accessibility, SEO, and performance QA checks pass.

30. PRD-to-TRD Traceability Matrix

PRD Area	TRD Coverage	Status
Product vision and hybrid booking	Architecture principles, appointment logic, API, status model.	Covered
MVP public website	Frontend, routes, SEO, content, responsive requirements.	Covered
Doctor/hospital/clinic profiles	Data model, admin CRUD, public profile requirements, schema.	Covered
Booking system	Booking workflow, slot logic, appointment API, transactions, validation.	Covered
Admin panel	Admin modules, RBAC, audit logs, metrics, operations.	Covered
Partner dashboard	Partner modules, scoped access, slot/appointment actions.	Covered
Notifications	WhatsApp integration, templates, queue, webhook, retry/failure handling.	Covered
SEO foundation	Metadata, sitemap, robots, schema, canonical, internal links.	Covered
Analytics	Event tracking table and privacy rules.	Covered
Security/privacy/compliance	RBAC, validation, rate limiting, legal pages, medical disclaimer, backups.	Covered
Performance/reliability	Core Web Vitals, caching, indexes, transactions, monitoring.	Covered
QA and acceptance	Testing strategy, milestones, definition of	Covered

	done.	
Risks/open decisions	Risk table, assumptions, open decisions.	Covered

Appendix A: Initial Environment Variables

Variable	Purpose	Required Environment
DATABASE_URL	PostgreSQL connection string.	Local/Staging/Production
NEXTAUTH_SECRET or AUTH_SECRET	Auth session signing secret.	All
NEXTAUTH_URL or APP_URL	Canonical application URL.	Staging/Production
WHATSAPP_API_TOKEN	WhatsApp provider API token.	Staging/Production
WHATSAPP_WEBHOOK_SECRET	Webhook verification secret.	Staging/Production
CLOUDINARY_URL or S3 credentials	Media storage configuration.	All
SENTRY_DSN	Error monitoring.	Staging/Production
GA4_MEASUREMENT_ID	Analytics tracking.	Production
RATE_LIMIT_SECRET/REDIS_URL	Rate limiting backend if needed.	Staging/Production